UNIVERSIDAD DE LAS FUERZAS ARMADAS ‘ESPE’

Departamento de Ciencias de la Computación

Ingeniería en tecnologías de la información

A.M. de Sistemas NRC-29293

ACTIVIDAD 3

Integrantes:

- Christopher Joel Armas Piarpuezan
- Daniel Alexis Quilca Andrade
- Isaac Sebastián Proaño Panchi
- Camila Nicole Shiguango Valverde

DOCENTE:

Ing. Hernán Jácome

1. **Como actividad de aprendizaje, los estudiantes analizarán un caso simulado en el que una empresa sufre una interrupción crítica de sus sistemas, con el fin de aplicar los conceptos estudiados. En el grupo, deberán identificar el tipo de desastre ocurrido y elaborar una descripción del DRP adecuado para atenderlo, explicar claramente su objetivo y la importancia de contar con este plan dentro de la organización. Posteriormente, relacionarán el incidente con la planificación de la continuidad del negocio (BCP), analizando su relevancia para mantener funciones esenciales durante la interrupción, determinando qué elementos debería incluir el plan y cómo se reflejan los componentes clave de resiliencia, recuperación y contingencia. Finalmente, el grupo incluirá sus conclusiones, promoviendo la comprensión integral de cómo el DRP y la BCP se complementan para garantizar la operatividad empresarial ante desastres.**

Empresa sufre una interrupción crítica de sus sistemas

SEGPRO

La transformación digital ha llevado a las organizaciones a depender cada vez más de sus sistemas de información. Desde un enfoque teórico, esta dependencia se puede entender a través del concepto de interconectividad crítica, que sugiere que la falla de un solo sistema puede provocar una serie de problemas en cadena, SEGPRO, es una empresa opera en el ámbito de la seguridad y vigilancia corporativa, enfrenta estos riesgos debido a su uso intensivo de plataformas digitales para monitoreo, comunicación y almacenamiento.

Identificación del desastre tecnológico en SEGPRO

El evento que hemos seleccionado es un ataque de Ransomware, ya que, según la ciberseguridad, el Ransomware se clasifica como una de las amenazas avanzadas persistentes, además debido a su habilidad para infiltrarse en sistemas, cifrar información y paralizar infraestructuras críticas.

Los marcos teóricos para el análisis de incidentes consideran este tipo de ataque como un desastre tecnológico de agresión deliberada, que afecta tanto la disponibilidad como la integridad y confidencialidad de los datos, las teorías de gestión del riesgo identifican estas amenazas como de alto impacto y alta probabilidad, especialmente en organizaciones que dependen de datos en tiempo real, como es el caso de SEGPRO

Fundamentos teóricos del DRP

El DRP se basa en estándares internacionales como ISO/IEC 27031 e ISO 22301, que ofrecen directrices para la preparación y recuperación de infraestructuras tecnológicas. Desde un punto de vista teórico, el DRP es una parte esencial del ciclo de vida de la gestión de continuidad, que incluye etapas de análisis, diseño, implementación y mejora continua.

Los principios que sustentan el DRP son:

- Redundancia tecnológica: se busca evitar puntos únicos de falla mediante el uso de servidores espejo, redes alternativas y sistemas replicados.
- Resiliencia sistémica: es la capacidad de un sistema para seguir operando incluso en condiciones adversas.
- Recuperación estructurada: se trata de una metodología que se basa en fases definidas, como contención, erradicación y restauración.

Elementos teóricos clave del DRP

Los elementos esenciales del DRP están íntimamente relacionados con modelos de recuperación que se encuentran en las teorías de seguridad informática. Algunos de los más destacados son:

a) Evaluación de riesgos: se apoya en metodologías como OCTAVE, NIST o análisis cualitativo/cuantitativo para identificar vulnerabilidades.

b) RTO y RPO: son conceptos teóricos fundamentales. El RTO (Recovery Time Objective) indica cuánto tiempo puede estar un sistema fuera de servicio sin que esto cause problemas graves. Por otro lado, el RPO (Recovery Point Objective) establece la cantidad máxima de datos que la organización está dispuesta a perder.

c) Estrategias de respaldo: fundamentadas en teorías de protección de datos, incluyen copias de seguridad completas, incrementales, diferenciales y la regla 3-2-1 (tres copias, dos tipos de almacenamiento, una copia fuera del sitio).

d) Plan de restauración: es un procedimiento guiado que sigue la metodología de “recuperación progresiva”, lo que significa que primero se restauran los servicios esenciales antes de abordar los complementarios.

Aplicación del DRP al caso de SEGPRO

Cuando aplicamos la teoría del DRP a SEGPRO, la activación sigue un proceso claro: primero detectamos, luego analizamos, después contenemos, erradicamos y finalmente nos recuperamos. Los modelos de respuesta a incidentes sugieren que es crucial capturar evidencias, aislar las redes afectadas, bloquear los vectores de ataque y restaurar desde copias de seguridad confiables. La recuperación debe apoyarse en sistemas que ya han sido validados para evitar cualquier reinfección. Además, desde la perspectiva

de la mejora continua, es recomendable realizar un análisis post-incidente para actualizar políticas, procedimientos y controles.

Elementos clave del BCP en SEGPRO

a) BIA (Análisis de Impacto en el Negocio): es una herramienta teórica que ayuda a identificar los procesos críticos, a determinar las interdependencias y a evaluar los impactos tanto económicos como operativos.

b) Estrategias de continuidad: basadas en la teoría de redundancia operativa, se centran en asegurar la continuidad de los servicios esenciales a través de sistemas alternativos o procedimientos manuales.

c) Recursos humanos: desde la perspectiva de la teoría organizacional, la continuidad depende de contar con equipos bien capacitados y roles claramente definidos.

d) Comunicación: apoyada en la teoría de gestión de crisis, establece protocolos claros para evitar la desinformación y minimizar el impacto en la confianza del cliente.

Relación teórica entre DRP, BCP y resiliencia organizacional

La resiliencia organizacional es un concepto que ha captado la atención en el ámbito de la administración moderna. Se refiere a la habilidad de una organización para enfrentar desafíos, adaptarse a ellos y recuperarse.

La resiliencia se basa en tres pilares fundamentales

- Anticipación: prepararse a través de un análisis de riesgos y la implementación de planes preventivos.
- Resistencia: la capacidad de seguir operando incluso bajo presión.
- Recuperación: el proceso de volver a la normalidad de manera ordenada.

Desde esta óptica, el DRP refuerza la recuperación tecnológica, mientras que el BCP asegura que la operación continúe sin interrupciones. Ambos son interdependientes y se integran en un modelo teórico de gestión integral de continuidad.

Las teorías sobre la continuidad del negocio, la gestión del riesgo y la resiliencia organizacional nos muestran que tener un Plan de Recuperación ante Desastres (DRP) y un Plan de Continuidad del Negocio (BCP) bien diseñado es crucial para minimizar los efectos de desastres tecnológicos. Dado su enfoque operativo, SEGPRO necesita contar con planes que estén bien estructurados y basados en estándares internacionales. Juntos, estos planes permiten manejar interrupciones de manera efectiva, reduciendo su impacto y garantizando que las operaciones sigan funcionando.

2. **Como actividad de aprendizaje, analizarán el proceso completo de creación de un** Plan de Recuperación de Desastres de TI (DRP de TI)**. En el grupo imaginar, que se les presentará un escenario donde una infraestructura tecnológica sufre una interrupción severa, y deberán diseñar un plan básico que incluya la identificación de sistemas críticos, la definición de estrategias de recuperación, y la estructura ideal recomendada por NIST para un DRP de TI. Posteriormente, siguiendo la guía de implementación, deberán describir los pasos necesarios para poner en marcha ese plan, desde la recolección de información técnica hasta las pruebas, ajustes y mantenimiento del mismo. Finalmente, el grupo comparará su propuesta con el modelo teórico, identificando brechas y justificando sus decisiones para asegurar una recuperación efectiva de los servicios TIC.**

Análisis del proceso completo de creación de un DRP

La elaboración de un Plan de Recuperación de Desastres (DRP) implica un proceso organizado que permite garantizar la continuidad operativa ante fallas

o incidentes severos. El análisis se basó en un escenario hipotético donde la infraestructura tecnológica sufre una interrupción grave.

Identificación de sistemas y procesos críticos:

- Sistemas de ventas y facturación.
- Bases de datos SQL Server y PostgreSQL.
- Sistema de inventarios.
- Servidores de producción.
- Servicios de red e Internet.
- CRM de atención al cliente.

Se definieron RTO entre 4 y 12 horas y RPO entre 1 y 6 horas según criticidad.

2. Diseño del Plan Básico de Recuperación de Desastres

Incluye estrategias como:

- Sitio alterno duplicado.
- Hot Site, Warm Site y Cold Site.
- Respaldos incrementales y completos.
- Redundancia de red e Internet.

Roles y responsabilidades:

- Comité de Recuperación de TI.
- Líder de Respuesta a Incidentes.
- Equipos técnicos y de comunicaciones.

Estructura basada en NIST SP 800-34:

1. Propósito del DRP.
2. Roles.
3. Inventarios.
4. BIA.
5. Riesgos.
6. Estrategias.
7. Respaldos.
8. Comunicación.
9. Procedimientos.
10. Pruebas.
11. Mantenimiento.

3. Pasos para la Implementación del DRP (NIST)

- Recolección de información técnica.
- Procedimientos de respaldo.
- Activación de estrategias de recuperación.
- Pruebas de escritorio, parciales y completas.
- Ajustes y mejoras.
- Mantenimiento del DRP.

4. Comparación entre la Propuesta del Grupo y el Modelo NIST

Coincidencias:

- Identificación correcta de criticidad.
- RTO/RPO adecuados.
- Estrategias recomendadas.
- Estructura alineada al NIST.

Brechas:

- Procedimientos detallados faltantes.
- Falta política formal de comunicación.
- No se definieron métricas de evaluación.
- No se incluyó cronograma de pruebas.

Justificación:

- Priorización de procesos comerciales por impacto.
- Enfoque complementario ISO 27005 + NIST.
- Nivel adecuado para un DRP inicial académico.

Conclusión:
El grupo elaboró un DRP básico pero completo, alineado al NIST, con identificación de brechas y decisiones justificadas.

3. **Analizar cómo una organización garantiza el funcionamiento eficiente de sus sistemas tecnológicos mediante tres procesos fundamentales:**

   a) **Realizar un diagnóstico de la infraestructura tecnológica, identificando fortalezas, debilidades y necesidades futuras**

b) Determinar los elementos tecnológicos mínimos, como hardware, software, redes y sistemas de almacenamiento necesarios para sostener las operaciones

c) Definir las políticas esenciales que regulan la seguridad, el uso aceptable de los recursos, los respaldos, el acceso a la información y el mantenimiento. Explicar cómo cada uno de estos componentes contribuye a mejorar la continuidad operativa, la seguridad de los datos y la eficiencia en la gestión de TI dentro de una organización.

ANÁLISIS DE PROCESOS

La organización SEGPRO asegura la eficiencia, continuidad y seguridad de sus sistemas tecnológicos mediante tres procesos fundamentales:

(a) el diagnóstico de la infraestructura tecnológica,

(b) la definición de requerimientos mínimos, y

(c) la creación de políticas que regulen el uso y seguridad de la información.

a) Diagnóstico de la infraestructura tecnológica: fortalezas, debilidades y necesidades futuras

SEGPRO realiza un diagnóstico completo que abarca:

Fortalezas

Posee sistemas tecnológicos clave como Procore, Microsoft Dynamics, SQL Server, Jaya y ERP que permiten gestionar ventas, inventarios, producción y atención al cliente.

Cuenta con servidores robustos (Windows Server 2016, OS X Server, Ubuntu) y equipos confiables para usuarios finales.

Hay un análisis claro de procesos críticos, RTO, RPO y activos críticos, lo que facilita planificar recuperaciones rápidas.

Debilidades

Dependencia fuerte de Internet y de sus servidores internos: un fallo detiene ventas, inventarios o producción.
Vulnerabilidades como: fallas eléctricas, malware, errores humanos y daños físicos, que fueron identificadas en el análisis de riesgos.
Necesidad de controles mejor estructurados, ya que algunos riesgos presentan niveles altos o críticos.

Necesidades futuras
Mayor redundancia (implementación de sitios alternos como Hot Site, Warm Site o Mirrored Site).
Capacitación continua del personal en DRP y seguridad.
Mejorar políticas de respaldo y protección ante ciberataques.
Actualización periódica del DRP y sistemas.

Cómo contribuye esto a la continuidad y seguridad:
El diagnóstico permite conocer qué procesos no pueden detenerse, qué sistemas son esenciales y dónde están los puntos débiles. Esto garantiza que la organización pueda prepararse para evitar fallas, responder más rápido ante incidentes y mantener la operación sin interrupciones prolonScamgadas.

b) Determinación de los elementos tecnológicos mínimos necesarios

Según el documento, SEGPRO identifica los recursos tecnológicos mínimos para sostener sus operaciones en cada proceso crítico.
Hardware mínimo
Servidores Dell / Mac Mini / Windows Server 2016.
Pc de usuario final Lenovo V15.
UPS para respaldo eléctrico (especialmente en inventarios y producción).

Software mínimo

Procore, Dynamics, Jaya, SQL Server, PostgreSQL, CRM (Salesforce), Microsoft Office.

Todos estos softwares son indispensables para ventas, inventarios, producción, atención al cliente y administración.

Redes y conectividad

Red de datos interna y conexión estable a Internet.

Seguridad de red con herramientas como Bitdefender / Symantec.

Monitoreo constante para evitar intrusiones.

Sistemas de almacenamiento y respaldo

Servidores dedicados al almacenamiento.

Sistemas de respaldo y recuperación de datos.

Sitios alternos (Hot, Warm, Cold Site y Mirrored Site) dependiendo de la gravedad del incidente.

Cómo contribuye a la eficiencia y continuidad:

Disponer de estos elementos asegura que cada área pueda operar sin interrupciones, que los datos estén protegidos y que existan alternativas para seguir trabajando incluso ante un desastre tecnológico.

c) Políticas esenciales: seguridad, uso aceptable, respaldos, acceso y mantenimiento

El documento evidencia que SEGPRO establece políticas claras relacionadas con:

1. Seguridad

Basadas en ISO 27005 y 22301.

Identificación de amenazas (malware, fallas eléctricas, errores humanos, robos).

Aplicación de controles para reducir riesgos.

2. Uso aceptable de recursos

El personal debe usar correctamente los sistemas y proteger la información.
Se establecen roles y responsabilidades dentro del DRP.

3. Respaldos

Frecuencias definidas según RPO (1 h, 2 h, 4 h, 6 h según proceso).
Uso de sistemas de recuperación (sitios alternos, backups automáticos).
Priorización de datos sensibles como ventas, inventarios y facturación.

4. Acceso a la información

Control de permisos basado en criticidad de procesos.
Protección de confidencialidad, integridad y disponibilidad de los activos.

5. Mantenimiento

Mantenimiento continuo de hardware y software.
Actualizaciones planificadas de sistemas críticos.
Monitoreo de seguridad 24/7.

Cómo contribuye a la seguridad y gestión TI:
Estas políticas evitan el uso indebido, reducen riesgos, protegen datos sensibles, aseguran que los sistemas estén siempre actualizados y permiten responder rápidamente ante un incidente. Así se garantiza la continuidad operativa y un funcionamiento tecnológico estable.

4. **Analizar cómo se estructura una solución tecnológica capaz de garantizar disponibilidad, seguridad y rendimiento dentro de una organización.**
Para ello, debe revisar los componentes esenciales, como la configuración de una red LAN segmentada en VLAN, la implementación de servidores físicos o virtuales con almacenamiento redundante, el uso de servicios en la nube para respaldo y colaboración, la aplicación de medidas de seguridad como firewalls, IDS/IPS y autenticación

multifactor, y la incorporación de herramientas de monitoreo para supervisar el funcionamiento de toda la infraestructura.

Explicar cómo estos elementos se integran entre sí para formar una infraestructura funcional, escalable y alineada con las necesidades operativas de la empresa.

Para garantizar la continuidad operativa de SEGPRO y soportar la ejecución eficiente de procesos críticos como la Gestión de Ventas y Control de Inventarios, se ha diseñado una arquitectura tecnológica. Esta solución integra principios de defensa en profundidad y alta disponibilidad para alinear la infraestructura TI con los objetivos estratégicos de la organización.

4.1. Configuración de Red LAN y Segmentación (VLANs)

Dada la estructura organizacional funcional de SEGPRO, es imperativo abandonar el uso de una red plana para evitar congestiones y riesgos de seguridad lateral. Se implementará una segmentación lógica mediante VLANs (Redes de Área Local Virtuales) en los switches administrables, distribuidas según los macroprocesos de la empresa:

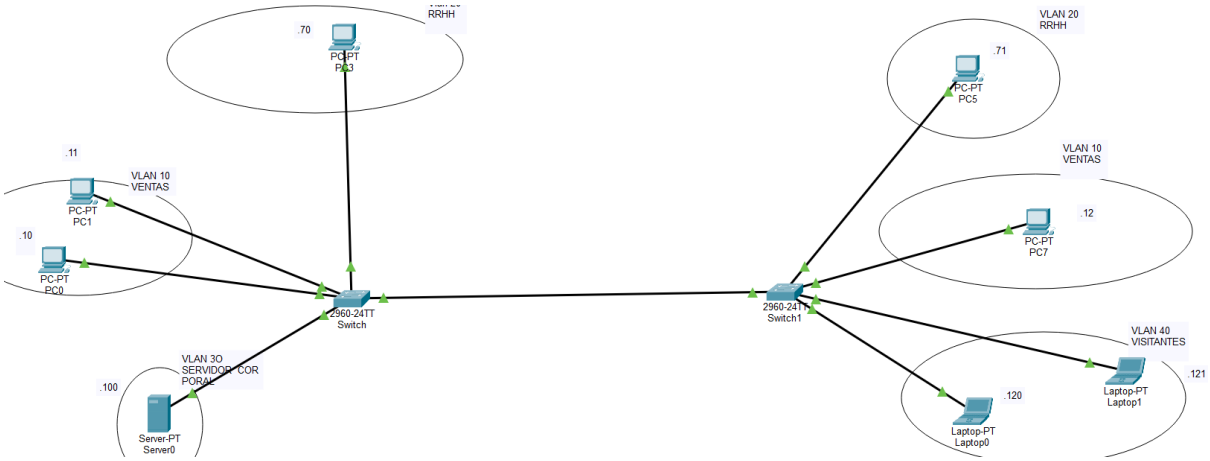
VLAN 10: Servidores: Zona restringida y priorizada para el tráfico de los servidores Dell y Mac mini que alojan sistemas core como Microsoft Dynamics y las bases de datos SQL Server.

VLAN 20: Gestión Administrativa y Financiera: Segmento exclusivo para el departamento Financiero, asegurando la confidencialidad de las transacciones en los sistemas Megued y Jaya.

VLAN 30: Comercial y Clientes: Red optimizada para el equipo de ventas y atención al cliente, garantizando ancho de banda para el CRM y plataformas de comunicación como Zendesk.

VLAN 40: Operaciones y Logística: Segmento dedicado al área de almacén y producción, separando el tráfico de los dispositivos de control de stock de la red administrativa.

VLAN 99: Gestión TI: Red oculta para la administración segura de los equipos de red y soporte técnico.



Ejemplo en cisco packet tracer

4.2. Servidores, Virtualización y Almacenamiento

Para optimizar los recursos de hardware existentes, como los servidores Dell con Windows Server 2016, migraremos de un modelo físico puro a una infraestructura virtualizada

Virtualización: Se implementará un hipervisor (tipo VMware vSphere o Microsoft Hyper-V) sobre el hardware físico. Esto permitirá ejecutar múltiples servidores virtuales aislados en el mismo equipo, destinando por ejemplo uno para las aplicaciones Procore y otro para la base de datos SQL Server. Esta separación facilita la recuperación ante desastres y permite un mejor aprovechamiento de la memoria y el procesador.

Almacenamiento Redundante (RAID): Los discos de los servidores se configurarán en arreglos RAID 5 o RAID 10. Esta configuración garantiza que, en caso de fallo físico de un disco duro, la información crítica de facturación e inventarios permanezca intacta y el sistema siga operando sin interrupciones, cumpliendo con los requisitos de disponibilidad del negocio

4.3. Servicios en la nube para respaldo y colaboración

Aplicaciones basadas en la nube como Procore, Jaya o Microsoft Office Business permite que los datos operativos se sincronicen automáticamente y se mantengan disponibles incluso si el sitio principal enfrenta problemas.

Colaboración y Productividad: mantendremos el uso de Microsoft Office 365 para el correo electrónico y la ofimática, lo que asegura que la comunicación con clientes y proveedores no se detenga, aunque el centro de datos local en Quito sufra un corte de energía

Respaldo en la Nube: para mitigar riesgos físicos como incendios o robos se configurarán copias de seguridad automatizadas de las bases de datos críticas como SQL Server y PostgreSQL ,hacia un repositorio seguro en la nube tipo Azure o AWS, garantizando así la recuperación de la información vital de SEGPRO fuera de las instalaciones principales.

4.4. Aplicación de medidas de seguridad como firewalls, IDS/IPS y autenticación multifactor

Para proteger los activos de información identificados como críticos, desplegaremos medidas de ciberseguridad escalonadas:

Firewall de Próxima Generación NGFW: Se instalará un dispositivo perimetral para filtrar todo el tráfico entrante y saliente, protegiendo la red interna contra accesos no autorizados desde Internet.

Sistemas IDS/IPS: Se activarán sistemas de Detección y Prevención de Intrusos para monitorear la red interna en busca de comportamientos anómalos como intentos de Ransomware o movimientos laterales, bloqueando amenazas antes de que afecten a los servidores.

Autenticación Multifactor (MFA): Se aplicará MFA obligatorio para todos los accesos remotos (VPN) y para las cuentas de correo corporativo de los usuarios, mitigando significativamente el riesgo de suplantación de identidad

4.5. Incorporación de herramientas de monitoreo para supervisar el funcionamiento de toda la infraestructura

Con el objetivo de mantener un rendimiento óptimo, integraremos una herramienta de monitoreo como Nagios, Zabbix o PRTG para supervisar la salud de la infraestructura las 24 horas del día:

Estado de los servicios críticos (SQL Server, Web Server).

Este sistema controlará constantemente el estado de los servicios críticos, el uso de recursos como CPU, memoria y disco en los servidores.

Disponibilidad de los enlaces de Internet. El sistema enviará alertas automáticas al personal de TI ante cualquier degradación del servicio, lo que permitirá una respuesta proactiva antes de que la operación comercial llegue a verse afectada.

5. **Se deberá elaborar un video explicativo que desarrolle los cuatro literales mencionados previamente, garantizando la participación activa de todos los integrantes del grupo.**
   El enlace del video deberá incorporarse en el mismo documento. Cada integrante deberá intervenir de manera visible durante la grabación.

   https://www.youtube.com/watch?v=bkxqJBUdTTo